



Cyber Attacks Explained

The Man In The Middle

Part—8

Due to the encouraging feedback this series of articles has received, we decided to explore yet another type of cyber intrusion—the Man In The Middle (MITM) attack, which is widely favoured by attackers. Unfortunately, many systems administrators don't seem to understand its severity. In this article, we will explore ways to protect FOSS infrastructure.

In a previous article, we learnt about various packet-spoofing attacks, and I also demonstrated how it can result in an MITM attack. However, since this type of attack is favoured by attackers, I thought it worthwhile to dedicate an article to it. MITM attacks are used mainly to steal information and data. They are possible by exploiting inherent vulnerabilities of the TCP/IP protocol at various layers. Technically speaking, these are a derivative of packet sniffing and spoofing techniques. If carried out properly, users can be completely oblivious to this attack, making it difficult to detect and stop. MITM attacks are sometimes called bucket brigade attacks, eavesdropping attacks, or connection hijacking attacks.

Please refer to Figure 1. At a macro level, the steps involved are to intercept traffic, break the authentication chain, and impersonate the endpoints seamlessly. The objective is to steal the session, and thus the information being transmitted. As we know, TCP/IP works on a three-way handshake (between SYN, SYN-ACK and ACK) that establishes a connection, which then uses packet sequencing and data acknowledgements to send or receive data. Data is passed between the (OSI) physical and application layers. At Layer 2 and Layer 3, Ethernet and IP packet datagrams are formed, whereas at the presentation layer, the cryptographic SSL session is established, assuming that the application is planning to use it. It is important to note that each of these layers can potentially participate in the MITM attack.

The table in Figure 2 maps the OSI layers to various

possible MITM attacks. To steal the session, the attackers need to first use a packet sniffer. After gathering packets, they choose which layer to attack—ARP protocol, IP or SSL. Next, the attackers use advanced tools to inject packets to steal the session without the knowledge of the victims whose session is being hijacked. Although MITM uses IP spoofing at its base, it goes a mile beyond that in order to gain control by choosing sessions from one or more layers to be hijacked. For example, the attackers can use ARP spoofing and also cryptographic session stealing to achieve complete control over an e-commerce transaction. Also, compared to just spoofing packets, MITM attacks modify the intercepted data and re-transmit it, making the victim believe the packet is from a legitimate source (which, in fact, is just another victim).

Since it can happen at various layers, the severity of an MITM attack can be very high. For example, a legitimate employee of a firm can use a MITM attack to download the HR database being viewed by a fellow HR employee, by stealing the session of the TCP port being used by the SQL server and the HR desktop application. Or credit card numbers could be stolen by hijacking a browser session connected to a shopping cart Web application. Advanced attackers can steal sessions established at lower OSI layers such as Layer 3, to dump all the packets and gain a deep insight into applications running on the particular computer, and the usage pattern and other personal details of the person using it. It is also possible to record an entire authentication session, and decipher the user